Platform first. Security first.

NexusOS: Business Operating System

Engineering case study · sole engineer

React 19 · TypeScript · FastAPI · Python 3.12 · PostgreSQL 16 · Redis 7

A multi-tenant business platform where authentication, authorization and tenant isolation are solved once as infrastructure, so every future module inherits them instead of reimplementing them.

RESULTS AT A GLANCE

167	111	89	157 · 31
BACKEND TESTS	OF THOSE, SECURITY TESTS	FRONTEND TESTS	DESIGN TOKENS · COMPONENTS

FEATURED PROJECT

NexusOS

MULTI-TENANT PLATFORM

React SPA on an async FastAPI service layer with a PostgreSQL tenant model: token-rotating authentication, per-tenant RBAC, rate limiting and company-scoped data isolation.

GITHUB github.com/waley7337

PYTHON · FASTAPI · POSTGRESQL · REDIS · REACT · TYPESCRIPT

NEXT: the full case study on the following pages → challenge, architecture, tenant isolation, decisions, current state

01 / THE CHALLENGE

The challenge

PROBLEM

Tenant is not an input

If a request can influence its company scope, isolation depends on every future endpoint author. Tenant must be **derived**, not accepted.

PROBLEM

A token is not authority

A signed JWT only proves issuance. Suspensions and role changes must take effect **immediately**, not at expiry.

PROBLEM

Email is not global identity

One person can hold accounts at two companies, so even **login needs tenant context**.

PROBLEM

Design is infrastructure

Ten modules styled separately means ten versions of a table. **Tokens and components come first.**

02 / ARCHITECTURE

Architecture



03 / HOW TENANT ISOLATION WORKS

How tenant isolation works

SOURCE	AUTHORITATIVE SOURCE PER REQUEST
User	Token subject locates a DB row that must be **active**
Tenant	Read from the stored user record, token claim **ignored**
Role	Re-read from the database on every request
Permissions	Flattened from role grants, never carried in a token
Session	Matched to a live server-side record

Application-level scoping

Queries are scoped by the server-derived company. The scoped repository **refuses to run** without one. Built and tested, not yet on live routes.

Composite foreign keys

Children reference **(parent_id, company_id)**, so the database rejects any cross-tenant link, covered by tests.

04 / KEY ENGINEERING DECISIONS

Key engineering decisions

DECISION	WHY	TRADE-OFF
Authorization re-derived from the database	Suspension and revocation apply on the next request.	One indexed query per protected request.
Rotating refresh tokens with reuse detection	A replayed token is treated as theft: all sessions revoked and audited.	More moving parts than one long-lived token.
Tenant scope derived server-side	The safe path becomes the only path for new endpoints.	Switching tenants means signing in again.
Tokens and primitives before modules	Every module inherits one table, error and empty state.	Time spent before shipping any feature.

05 / CURRENT STATE

Current state

IMPLEMENTED

- Full auth lifecycle with token rotation
- Per-tenant RBAC, fail-closed
- Rate limiting, audit log, trusted-proxy IPs
- Frontend platform and design system
- CI: lint, types, migrations, tests

FOUNDATION ONLY

- 38 domain models migrated, no endpoints
- Dashboard built on fixture data
- Scoped repository, not on live routes
- Email delivery is a logging stub

PLANNED

- CRM, projects, finance, HR, inventory
- AI assistant and reports
- Row-level security as a second layer
- Notifications, files, exports

06 / DELIBERATELY NOT CLAIMED

Deliberately not claimed

PostgreSQL row-level security | CSP / Permissions-Policy | JWT issuer + audience | Access-token revocation before expiry | Account lockout | Verified-email enforcement

Controls that are absent or deliberately deferred are listed rather than omitted. All claims verified against the implemented codebase.